

实验一、 fscan 综合扫描实验

1.知识介绍

fscan 是一款内网综合扫描工具，方便一键自动化、全方位漏扫扫描。支持主机存活探测、端口扫描、常见服务的爆破、ms17010、redis 批量写公钥、计划任务反弹 shell、读取 win 网卡信息、web 指纹识别、web 漏洞扫描、域控识别等功能。

2.实验环境

操作系统：靶机、扫描机使用 windows 10、windows 7 均可

工具：fscan 1.8.1

3.实验目的

本实验具有明显的针对性和实用性，目的在于使学生通过对本实验执行过程的理解，了解一些网络扫描工具的使用，加强在网络安全领域中的防范意识。

4.实验内容

本实验主要使用 fscan 工具，对指定的域名或者 IP 进行多类型的扫描，包含了密码爆破，网段批量扫描和 POC 检测等内容。

5.考核目标

- （1）40%：完成网段批量部分内容
- （2）60%：完成 ssh 命令执行部分内容
- （3）80%：完成扫描指定域名部分内容
- （4）100%：结合抓包工具和网络协议知识分析至少一种扫描的原理。

6.实验步骤

6.1 批量扫描网络信息

fscan 带有批量扫描的功能，主要就是为了查看网段内部主机的基本网络信息，其使用方式也很简单，就是在扫描的时候在参数“-h”的后面加上CIDR形式的IP地址，现在直接在命令窗口执行“fscan -h 192.168.122.0/24”，扫描的就是网络号为“192.168.122.0”的C段地址

```
C:\fscan>fscan -h 192.168.122.0/24
```

执行结果为：

```
start infoscan
(icmp) Target 192.168.122.1 is alive
(icmp) Target 192.168.122.75 is alive
(icmp) Target 192.168.122.158 is alive
[*] icmp alive hosts len is: 3
192.168.122.158:445 open
192.168.122.75:445 open
192.168.122.158:139 open
192.168.122.75:139 open
192.168.122.158:135 open
192.168.122.75:135 open
192.168.122.1:22 open
192.168.122.158:7680 open
[*] alive ports len is: 8
start vulscan
[+] NetInfo:
[*] 192.168.122.158
[->] DESKTOP-4EL0QSM
[->] 192.168.122.158
[+] 192.168.122.75 MS17-010 (Windows Server 2003 3790 Service Pack 2)
[+] NetInfo:
[*] 192.168.122.75
[->] zxiat
[->] 192.168.122.75
[*] 192.168.122.75 [ ] _MSBROWSE_ \ZXIAT Windows Server 2003 3790 Service Pack 2
已完成 7/8 [-] ssh 192.168.122.1:22 root test ssh: handshake failed: ssh: unable to authenticate, attempted methods
e password], no supported methods remain
已完成 7/8 [-] ssh 192.168.122.1:22 root Aa123456! ssh: handshake failed: ssh: unable to authenticate, attempted met
[none password], no supported methods remain
```

可以看到，不加扫描模块参数执行的话，会扫描该网络的存活主机，检测每台存活主机的一些常用端口是否开启，除此之外还有显示主机的网卡信息，一些常见漏洞，在显示信息的最下面，fscan 还尝试通过自带的字典对22 端口开启 ssh 服务的主机进行爆破。

6.2 ssh 攻击执行命令

刚才也提到过，fscan 可以对开启 ssh 服务的目标主机实施弱口令爆破，

6.3 指定域名的网站漏洞检测

除了扫描 IP 之外，fscan 还可以自动探测出指定域名的 IP 并且扫描一些基本信息，还可基于 PoC 检测一些可能出现的漏洞。同时扫描多个域名，就可以新建一个文本文件，然后将所有域名添加进去，例如在软件的同目录下创建一个文本文件“url.txt”，然后在里面加入一些测试域名：



url.txt - 记事本

文件(F) 编辑(E) 格式(O) 查看(V) 帮助(H)

http://demo.testfire.net

http://testphp.vulnweb.com

http://testasp.vulnweb.com

http://testaspnet.vulnweb.com

http://zero.webappsecurity.com

http://crackme.cenzic.com|

http://www.webscantest.com

http://scanme.nmap.org

然后就可以执行命令“fscan -uf url.txt”

```
C:\fscan>fscan -uf url.txt
```

即可看到扫描结果：

```

  A-SERCK
  fscan version: 1.8.1
start infoscan
[*] WebTitle:http://testphp.vulnweb.com code:200 len:4958 title:Home of Acunetix Art
[*] WebTitle:http://scanme.nmap.org code:200 len:4782 title:Go ahead and ScanMe!
[*] WebTitle:http://demo.testfire.net code:200 len:9369 title:Altoro Mutual
[*] WebTitle:http://www.webscantest.com code:403 len:286 title:403 Forbidden
[*] WebTitle:http://zero.webappsecurity.com code:200 len:12471 title:Zero - Personal Banking - Loans - Credit Cards
[*] WebTitle:http://testaspnet.vulnweb.com code:200 len:14085 title:acublog news
[*] WebTitle:http://testasp.vulnweb.com code:200 len:3540 title:acuforum forums
+ http://testphp.vulnweb.com/index.zip poc-yaml-backup-file
+ http://testphp.vulnweb.com poc-yaml-phpstudy-nginx-wrong-resolve php
已 完成 8/8
[*] 扫描结束,耗时: 1m35.595629s
```

在这里的执行结果中，除了网站的标题，状态码和相应数据长度之外，还可看到检测到了两个 POC 所对应的漏洞，分别是“poc-yaml-backup-file”和“poc-yaml-phpstudy-nginx-wrong-resolve”。

6.4 分析实验原理

实验的基本内容如上述所示，介绍了几种简单的 fscan 的功能和操作方式。在实验的最后，有能力的同学可以尝试着自己去安装一些数据包分析软件（如 wireshark 等）将抓包过程记录下来，分析一下软件探测扫描功能的原理。